Project 4: AWS Threat Detection, Monitoring, Incident Response & Forensics

Digital Egypt Pioneers Initiative – Graduation Project Documentation

1. Project Planning & Management

1.1 Project Proposal

Overview. Organizations moving to AWS need to see what is happening in their accounts, detect attacks early, and respond in a repeatable, evidence-preserving way. This project builds a complete security operations capability on AWS: centralized logging, managed threat detection, hands-on incident response and forensics, and automated response with executive reporting.

Objectives

- Build a tamper-resistant logging and audit foundation (CloudTrail org trail, CloudWatch Logs, AWS Config, VPC Flow Logs, S3 and ELB access logs) queryable with Athena.
- Enable and tune AWS threat detection services (GuardDuty, Security Hub, Detective, Inspector, Macie, Trusted Advisor, Config rules) and map findings to MITRE ATT&CK.
- Simulate three incidents (compromised EC2, exposed access keys, public S3 bucket) and practice containment, forensics and chain of custody.
- Automate response with EventBridge, Lambda, SSM Automation and Security Hub custom actions in a SOAR-style design.
- Produce technical and executive incident reports with lessons learned.

Scope

In scope	Out of scope
Single AWS Organization (or one management + one workload account) in one primary region	Production workloads or real customer data
Logging, detection, IR, forensics and automation on AWS-native services	Third-party SIEM/SOAR licensing
Simulated attacks run only in our own lab accounts	Offensive testing against any system we do not own
Playbooks, runbooks, reports, demos	24/7 SOC staffing model

Assumptions. Team has AWS accounts with Organizations access; costs stay within a lab budget enforced by AWS Budgets; all simulations are authorized and contained.

1.2 Project Plan

Timeline (Gantt)

Activity	Wk 1	Wk 2	Wk 3	Wk 4
Team formation, role split, kickoff	■			
Logging architecture and org trail	■			
Config recorder, Flow Logs, S3/ELB logs	■			
Athena queries and log inventory	■			

Activity	Wk 1	Wk 2	Wk 3	Wk 4
Enable GuardDuty, Security Hub, Detective, Inspector, Macie		■		
Config rules, Trusted Advisor review		■		
Finding triage and MITRE ATT&CK mapping		■		
Incident simulations (EC2, keys, S3)			■	
Containment and forensic collection			■	
Timeline, RCA, chain-of-custody notes			■	
EventBridge / Lambda / SSM automation				■
SOAR playbooks and Security Hub custom actions				■
Final IR report, executive summary, presentation				■

Milestones

Milestone	Target	Exit criteria
M0 – Team formed	End of week 1 of booklet	Group list sent to instructor
M0b – Responsibilities submitted	Within 2 weeks of booklet	Role table sent to instructor
M1 – Logging foundation live	End of project week 1	Org trail, Config, Flow Logs delivering to S3/CloudWatch; Athena queries return data
M2 – Detection baseline	End of project week 2	All services enabled; sample findings triaged and mapped
M3 – IR exercises complete	End of project week 3	3 playbooks executed; evidence and timeline documented
M4 – Automation and final report	End of project week 4	Automated response demo works; reports and presentation ready

Deliverables by week

Week	Deliverables
1	Log architecture diagram, org trail, Config recorder, log retention policy, Athena queries, audit log inventory
2	Detection baseline, GuardDuty/Security Hub findings, Config rules, Inspector scan, triage notes, MITRE mapping
3	IR playbooks, containment checklist, forensic evidence collection, timeline, root cause analysis, chain-of-custody notes
4	Automated response playbook, EventBridge/Lambda demo, SOAR design, final IR report, executive summary, lessons learned

Resource allocation

- **People:** 6 team members (see 1.3), instructor as reviewer.
- **AWS services:** Organizations, CloudTrail, CloudWatch, Config, S3, Athena, GuardDuty, Security Hub, Detective, Inspector, Macie, Trusted Advisor, EventBridge, Lambda, Systems Manager, EC2/EBS, IAM, KMS, SNS.
- **Tools:** draw.io for diagrams, GitHub for versioned playbooks and IaC, a shared document workspace for reports.
- **Budget control:** AWS Budgets alerts at 50%, 80% and 100% of the lab limit; GuardDuty/Macie/Inspector enabled on trial where available; resources torn down after each lab.

1.3 Task Assignment & Roles

Roles below cover every item in the DEPI Project Documentation Guidelines: planning, literature review, requirements, system analysis and design, implementation, testing and final reports. Work is balanced by effort rather than item count (effort points are estimates, 1 = about half a day). Menna and Muhammad carry the heaviest technical weeks (Week 3 with the final report, and Week 4), so they carry the fewest analysis and design documents. Every member also writes the source code, README section, test cases and final-report section for their own week, supplies their own slides, and presents their own work. Roles must be sent to the instructor within two weeks of the booklet announcement.

Summary by member

Member	Technical week and implementation	Planning & requirements (16 Oct)	Analysis & design (6 Nov)	Implementation extras, testing & final reports (4 Dec)	Total points
Member 1: Ganna Mohamed	Week 1 – Logging & Audit: log architecture diagram, org trail, Config recorder, retention policy, Athena queries, audit log inventory (5)	6	7	6	24
Member 2: Mariam Ahmed	Week 2 – Threat Detection: detection baseline, GuardDuty/Security Hub findings, Config rules, Inspector scan, triage notes, MITRE mapping (5)	6	5	5	21
Member 3: MennaTullah Hisham	Week 3 and final report – compromised EC2 playbook, quarantine and role-session revocation, EBS snapshot and evidence collection, chain-of-custody notes, timelines and root cause analysis for all three scenarios (5)	5	1	7	18
Member 4: Muhammad Hossam	Week 4 – Automation core: automated response playbook, EventBridge/Lambda demo, SSM Automation, SOAR design, final IR report (4)	5	1	4	14
Member 5: Esraa Mahmoud	Week 3 – exposed access keys and public S3 bucket playbooks, containment checklist (3)	–	6	–	9
Member 6: Abullah Mohamed	Week 4 – Security Hub custom actions, SNS notifications, lessons learned, executive summary (2)	–	7	–	9

Detailed split by guideline item

Phase (deadline)	Item	Owner	Points
Planning & management (16 Oct)	1.1 Project Proposal	Ganna	2
	1.2 Project Plan (Gantt, milestones, resources)	Ganna	3
	1.3 Task Assignment & Roles	Ganna	1
	1.4 Risk Assessment & Mitigation Plan	Mariam	2
	1.5 KPIs	Mariam	2
Literature review (16 Oct)	2.1–2.3 Background, Feedback & Evaluation, Suggested Improvements	Muhammad	3
	Final Grading Criteria	Mariam	1
Requirements gathering (16 Oct)	3.1 Stakeholder Analysis	Mariam	1
	3.2 User Stories & Use Cases	Menna	3
	3.3 Functional Requirements	Menna	2

Phase (deadline)	Item	Owner	Points
	3.4 Non-functional Requirements	Muhammad	2
System analysis & design (6 Nov)	Problem statement and objectives	Menna	1
	Use case diagram and descriptions	Esraa	2
	Security/system architecture	Ganna	3
	Data model: ER diagram and schema for logs, findings, incidents, evidence	Mariam	3
	Data flow diagrams (context and detailed)	Mariam	2
	Sequence diagrams	Esraa	2
	Activity and state diagrams (incident lifecycle)	Esraa	2
	Class/component diagram	Abdullah	2
	Dashboard wireframes and UI/UX guidelines	Abdullah	3
	Technology stack	Ganna	1
	Deployment diagram	Ganna	2
	API/interface documentation (EventBridge, Lambda, SSM)	Muhammad	1
	Testing and validation plan	Abdullah	2
	Deployment strategy	Ganna	1
Implementation (30 Nov)	Source code, IaC and scripts for own week	Each member	in weekly points
	Version control: GitHub repository, branching strategy, commit history, CI/CD	Ganna	3
	README: installation, requirements, configuration, execution guide	Mariam	2
Testing & QA (4 Dec)	Test cases & test plan	Ganna	3
	Automated testing scripts	Menna	2
	Bug reports	Menna	2
Final presentation & reports (4 Dec)	User manual	Muhammad	2
	Technical documentation (compiles architecture, schema, interfaces)	Menna	3
	Project presentation (assembly; each member supplies own slides)	Mariam	3
	Video demonstration (optional)	Muhammad	2

Official deadlines (DEPI track)

Phase	Deadline
Project Planning & Management	16 Oct 2026
Literature Review	16 Oct 2026
Requirements Gathering	16 Oct 2026
System Analysis & Design	6 Nov 2026
Implementation (source code & execution)	30 Nov 2026
Final Presentation, Testing & Reports	4 Dec 2026

All documents must be uploaded to GitHub. The weekly technical deliverables (Weeks 1–4) are carried out as part of the implementation phase and are due by 30 Nov 2026.

Collaboration rules. Weekly planning call, mid-week check-in, all artifacts committed to a shared repository, every deliverable peer-reviewed by one other member before submission. Each member owns one area but pairs with another on a second area so no work is single-person-dependent.

1.4 Risk Assessment & Mitigation Plan

#	Risk	Likelihood	Impact	Mitigation
R1	Unexpected AWS cost (GuardDuty, Macie, Config, logging volume)	Medium	High	AWS Budgets and alerts, lifecycle rules on log buckets, disable or tear down after labs
R2	Simulated attack affects real resources	Low	High	Isolated lab VPC/account, authorized scope only, SCP and IAM boundaries, no real data
R3	Logs missing or tampered with	Low	High	Org trail with log file validation, S3 versioning, Object Lock or restricted bucket policy, KMS encryption
R4	Detection services produce few findings in a short window	High	Medium	Use GuardDuty and Security Hub sample findings plus controlled simulations
R5	Too many false positives or alert noise	Medium	Medium	Tune Config rules, suppression rules, severity thresholds, document triage reasoning
R6	Automation causes unintended isolation or deletion	Medium	High	Test on tagged lab resources only, approval step for destructive actions, dry-run mode in Lambda
R7	Evidence handling errors weaken forensic value	Medium	Medium	Written chain-of-custody template, hashing of snapshots and exports, read-only evidence bucket
R8	Team member unavailable or uneven workload	Medium	Medium	Paired ownership, weekly check-in, shared documentation, instructor escalation if needed
R9	Schedule slip in week 3–4	Medium	High	Prepare simulation scripts in week 2, freeze scope at end of week 3, report drafted incrementally
R10	Credential leakage in repo or screenshots	Medium	High	Secrets scanning, redact keys, rotate any test key immediately after use

1.5 KPIs (Key Performance Indicators)

KPI	Target	How measured
Log source coverage	100% of planned sources (CloudTrail, Config, Flow Logs, S3, ELB) delivering	Audit log inventory vs. enabled sources
Log delivery latency	CloudTrail events queryable in Athena within 15 minutes	Timed test event
Detection service coverage	7 of 7 planned services enabled in all in-scope accounts	Security Hub / console check
Findings triaged and mapped to MITRE ATT&CK	100% of sample and simulated findings	Triage notes and mapping table
Mean time to detect (MTTD) in simulations	≤ 15 minutes for each of the 3 scenarios	Timeline from attack action to finding
Mean time to respond, manual	≤ 30 minutes per scenario	Timeline from finding to containment
Mean time to respond, automated	≤ 2 minutes for automated scenarios	EventBridge/Lambda execution timestamps
Playbooks executed successfully	3 of 3	Evidence in IR report
Evidence integrity	100% of artifacts hashed and logged in chain of custody	Custody log
Deliverables on time	100% of weekly deliverables submitted	Plan tracking

KPI	Target	How measured
System availability of logging pipeline	No gaps in CloudTrail/Config recording	CloudTrail and Config health checks
Cost control	Spend ≤ lab budget	AWS Budgets report

2. Literature Review

2.1 Background and Reference Frameworks

The project is grounded in widely used references rather than ad-hoc practice:

- **AWS Security Incident Response Guide** and the **Well-Architected Framework (Security pillar)** for logging, detection and IR design on AWS.
- **NIST SP 800-61 (Computer Security Incident Handling Guide)** for the IR lifecycle: preparation, detection and analysis, containment, eradication and recovery, post-incident activity.
- **MITRE ATT&CK for Cloud (IaaS)** for describing adversary behavior and mapping findings to tactics and techniques.
- **CIS AWS Foundations Benchmark** and **AWS Foundational Security Best Practices** , used as the Security Hub standards for the detection baseline.
- **NIST SP 800-86 and ISO/IEC 27037** for evidence identification, collection and preservation, which inform the chain-of-custody notes.
- **AWS service documentation** for GuardDuty, Security Hub, Detective, Inspector, Macie, Config, EventBridge and SSM Automation.

2.2 Suggested Improvements

Areas where the project can be enhanced beyond the booklet scope:

1. **Amazon Security Lake** to normalize logs into OCSF and centralize multi-account data for analytics.
2. **Detection as code:** store Config rules, EventBridge patterns and Athena queries in Git, deploy with Terraform or CloudFormation, and test them in CI.
3. **Step Functions orchestration** with a human approval step for high-impact actions (for example, isolating a production instance).
4. **Ticketing and chat integration:** send findings to Jira/ServiceNow and Slack or Teams via SNS and Lambda.
5. **Attack simulation library** (for example Stratus Red Team) to repeat detections consistently and measure coverage against ATT&CK techniques.
6. **Automated forensics:** isolated forensic VPC, automatic EBS snapshot sharing to an analysis account, memory capture where feasible.
7. **Multi-account and multi-region rollout** using a delegated administrator for GuardDuty and Security Hub.
8. **Metrics dashboard:** CloudWatch or QuickSight dashboard tracking MTTD, MTTR, open findings and cost.
9. **Tabletop exercise** with the instructor playing the stakeholder to rehearse the executive communication.

Final Grading Criteria

Proposed breakdown (confirm final weights with the instructor):

Component	Marks	What is assessed
Documentation	25	Proposal, plan, roles, risks, KPIs, requirements, architecture diagrams, final IR report, executive summary
Implementation	40	Working logging foundation, enabled detection services, executed IR scenarios, EventBridge/Lambda automation, SOAR design
Testing	15	Athena query results, finding triage, simulation evidence, automation tests, KPI measurements
Presentation	20	Clear demo, adherence to deliverables, each member explaining their assigned work, Q&A
Total	**100**	

The final evaluation is based on the final presentation, which must show adherence to the deliverables and the distribution of tasks among team members.

3. Requirements Gathering

3.1 Stakeholder Analysis

Stakeholder	Role	Key needs
Instructor / evaluators	Assess the graduation project	All weekly deliverables, clear task distribution, working demo
Project team	Build and present	Clear scope, shared tooling, achievable timeline
Security operations team (SOC analysts)	Daily users of detection and logs	Reliable logs, prioritized findings, runbooks, fast queries
Incident responders / forensic analysts	Handle incidents	Containment procedures, preserved evidence, chain of custody
Cloud / DevOps engineers	Own the workloads	Minimal disruption, clear isolation rules, notifications
Management / executives (CISO, CIO)	Decision makers	Plain-language reports, risk and impact, lessons learned
Compliance and audit	Verify controls	Log retention, audit trail, evidence integrity
Finance / budget owner	Control spend	Predictable, capped costs
AWS (service provider)	Shared responsibility partner	Use within service limits and acceptable-use policy

3.2 User Stories & Use Cases

User stories

ID	As a…	I want…	So that…
US1	SOC analyst	all API activity from every account in one trail	I can investigate across accounts
US2	SOC analyst	to query logs with Athena	I can answer “who did what, when” quickly
US3	Security engineer	GuardDuty and Security Hub findings in one place	I can prioritize by severity
US4	Analyst	findings mapped to MITRE ATT&CK	I can describe attacker behavior consistently
US5	Responder	to isolate a compromised EC2 instance in one step	the attacker cannot move laterally

ID	As a…	I want…	So that…
US6	Responder	to snapshot EBS volumes with hashes recorded	evidence stays admissible and intact
US7	Cloud admin	exposed access keys to be disabled and rotated automatically	damage is limited before I wake up
US8	Cloud admin	a public S3 bucket to be flagged and remediated	data is not exposed
US9	CISO	a short executive summary after each incident	I can make decisions and report upward
US10	Auditor	log retention and integrity proof	I can verify compliance

Use cases

UC	Name	Actor	Main flow	Outcome
UC1	Centralize logging	Logging engineer	Create org trail → enable Config, Flow Logs, S3/ELB logs → deliver to S3/CloudWatch → create Athena tables	Searchable audit trail
UC2	Triage a finding	SOC analyst	Receive GuardDuty/Security Hub finding → review in Detective → classify true/false positive → map to ATT&CK → record notes	Documented triage decision
UC3	Compromised EC2	Responder	Alert on suspicious instance → replace security group with isolation SG → snapshot EBS → capture logs → revoke instance role sessions → analyze → rebuild	Contained incident with evidence
UC4	Exposed access keys	Responder	Detect key use from unusual source → deactivate key → review CloudTrail activity → rotate and reissue → add detection	Credential risk removed
UC5	Public S3 bucket	Responder	Config rule or Macie/Security Hub flags bucket → apply Block Public Access → review access logs → assess data exposure	Exposure closed and assessed
UC6	Automated response	Automation engineer	Finding event → EventBridge rule → Lambda or SSM Automation → remediation → SNS notification → Security Hub status update	Response without manual steps
UC7	Report incident	Project lead	Compile timeline and RCA → write technical report → write executive summary → record lessons learned	Final reports

3.3 Functional Requirements

Logging & audit

- FR1: The system shall record all management events from all organization accounts through an organization CloudTrail with log file validation enabled.
- FR2: The system shall send logs to S3 and CloudWatch Logs with defined retention periods.
- FR3: The system shall enable AWS Config recording for supported resources and deliver snapshots and history to a central bucket.
- FR4: The system shall enable VPC Flow Logs, S3 server access logs and ELB access logs.
- FR5: The system shall provide Athena tables and saved queries for CloudTrail, Flow Logs and access logs.
- FR6: The system shall maintain an audit log inventory listing each source, destination, retention and owner.

Threat detection

- FR7: The system shall enable GuardDuty, Security Hub, Detective, Inspector and Macie, and review Trusted Advisor checks.

- FR8: The system shall deploy Config rules for key controls (for example public S3 buckets, unrestricted security groups, root MFA, unencrypted volumes).
- FR9: The system shall aggregate findings in Security Hub using selected standards.
- FR10: The team shall triage sample findings and map each to a MITRE ATT&CK tactic and technique.

Incident response & forensics

- FR11: The team shall provide IR playbooks for compromised EC2, exposed access keys and public S3 bucket.
- FR12: The system shall support instance isolation using a dedicated quarantine security group.
- FR13: The team shall be able to revoke IAM access, deactivate and rotate keys, and invalidate active role sessions.
- FR14: The team shall snapshot EBS volumes and capture relevant logs, recording hashes and handler details in a chain-of-custody record.
- FR15: The team shall produce an incident timeline and root cause analysis for each scenario.

Automation & reporting

- FR16: The system shall trigger automated responses from findings using EventBridge rules.
- FR17: The system shall run remediation through Lambda and SSM Automation documents.
- FR18: The system shall provide Security Hub custom actions for analyst-initiated response.
- FR19: The system shall notify responders through SNS (email or chat) on detection and on automated action.
- FR20: The team shall deliver a SOAR-style design, a technical IR report, an executive summary and lessons learned.

3.4 Non-functional Requirements

Category	Requirement
Security	Least-privilege IAM roles for all automation; MFA on human users and root; logs encrypted with KMS; log buckets with restricted write access, versioning and Block Public Access; separation between workload and logging accounts
Integrity & auditability	CloudTrail log file validation; evidence stored in a write-restricted bucket; hashes recorded for every evidence item
Performance	Events queryable within about 15 minutes; automated response starts within 1 minute of a finding; Athena queries partitioned to keep scans small
Reliability	No gaps in CloudTrail or Config recording; automation retries and dead-letter queue for failed Lambda invocations; multi-AZ log storage through S3
Scalability	New accounts onboarded through the organization with the same configuration; log volume handled by S3 and lifecycle policies
Usability	Playbooks and runbooks written as numbered steps with screenshots or CLI commands; dashboards and summaries readable by non- technical stakeholders
Maintainability	Infrastructure as code (CloudFormation or Terraform); version-controlled playbooks and queries; consistent tagging
Cost	Spend within lab budget; lifecycle policies move older logs to cheaper storage; resources removed after labs

Category	Requirement
Compliance	Retention aligned to chosen policy; evidence handling follows NIST/ISO guidance; controls traceable to frameworks (CIS, NIST)
Safety of simulations	All attacks run only in authorized lab resources; destructive automation requires tags or approval
Documentation	Every deliverable versioned, peer-reviewed and linked to its owner